

Alejandro Molina De Haro

25/03/2026

PARTE 9 – Investigación forense y toma de decisiones

1. Reconstrucción del ataque

El ataque comienza cuando el atacante despliega un punto de acceso falso (rogue AP) llamado IES_iMES_FREE, configurado en el mismo canal (canal 6) que la red legítima IES_iMES. Esto le permite interferir y atraer a los dispositivos.

Punto de entrada del atacante:

El atacante crea una red Wi-Fi abierta con un nombre muy similar a la original, pero con más potencia de señal.

Cómo consigue que los alumnos se conecten:

Cuando el alumno se desconecta de la red legítima (08:18), su dispositivo se conecta automáticamente a la red abierta IES_iMES_FREE, ya que no requiere contraseña y tiene mejor señal.

Qué ocurre durante la navegación:

Una vez conectado:

- El alumno accede a una web como Instagram.
- El atacante intercepta la conexión (Man-in-the-Middle).
- Se produce una redirección a una página externa sin HTTPS.
- En esa página falsa, el usuario introduce sus credenciales, que son robadas.

Relación entre la Wi-Fi falsa y el correo:

El atacante utiliza también phishing por correo para reforzar el ataque:

- Envía correos desde un dominio falso (imes-edu.com).
- SPF falla y no hay DKIM.
- Refuerza la suplantación o distribuye malware.

2. Identificación de técnicas utilizadas

Evil Twin:

Red Wi-Fi falsa con nombre similar.

Evidencias: misma frecuencia, red abierta, nombre parecido.

Man-in-the-Middle:

Intercepta tráfico del usuario.

Evidencias: redirección, página sin HTTPS, robo de datos.

Phishing:

Correos falsos del instituto.

Evidencias: SPF FAIL, DKIM NONE, dominio falso.

Rogue Access Point:

Punto de acceso no autorizado.

Evidencias: red desconocida con nombre similar.

3. Toma de decisiones

Prioridad:

1. Wi-Fi falsa (impacto muy alto)
2. WPS activado (impacto muy alto)
3. Contraseña repetida (impacto alto)
4. Falta de segmentación (impacto alto)
5. Phishing (impacto alto)

4. Respuesta técnica inmediata

Router:

```
interface wlan0
```

```
no wps enable
```

```
security wpa3 enable
```

Firewall:

```
iptables -A INPUT -s 185.XX.XX.23 -j DROP
```

Correo:

```
SPF: v=spf1 mx -all
```

Clientes:

```
nmcli connection delete IES_iMES_FREE
```

5. Detección del ataque

Herramientas:

Wireshark, Aircrack-ng, SIEM

IoC:

- Red falsa
- Web sin HTTPS
- SPF FAIL
- IP sospechosa

6. Mejora del sistema

WPA3-Enterprise:

Seguridad avanzada con autenticación individual.

IDS/IPS:

Detecta y bloquea ataques en red.